

BEFORE Placeholder

AFTER

Supplier Incident Management Playbook (Internal)

Document classification: Internal

Document owner: Security Incident Lead

Program owner: Third-Party Security Program Owner

Version: 0.1

Effective date: _____

Review cadence: Annually (and after major incidents)

1. Purpose

This playbook defines the end-to-end approach for managing third-party supplier incidents that may impact organisational data, systems, or critical services, including immediate triage, containment, supplier engagement, privacy/legal actions, decision-making, and closure.

2. Scope

Applies to:

- any supplier-provided service (SaaS, MSP, hosting, software, outsourced operations), and
- any incident reported by a supplier, detected internally, or identified via credible intelligence, where the supplier may affect confidentiality, integrity, availability, or compliance/privacy outcomes.

3. Objectives

- Establish rapid situational awareness and confirm organisational impact.
- Contain exposure (access, connectivity, secrets, integrations) quickly and safely.

- Meet internal and external notification obligations (privacy/regulatory/customer) as applicable.
- Reassess supplier posture and decide whether to continue, restrict, suspend, or offboard.
- Capture evidence and lessons learned to improve controls and operating model.

4. Roles and responsibilities (generic)

- **Security Incident Lead (SIL):** coordinates incident response activities and technical triage.
- **Third-Party Security Program Owner (TPSPO):** owns supplier assurance, decisions, records, and governance escalation.
- **Security Engineering/Architecture (SEA):** performs control reassessment, defines remediation and compensating controls.
- **IT/Platform Owner (ITPO):** executes technical containment actions (access, connectivity, key rotation, integration changes).
- **Business Service Owner (BSO):** validates business impact, workaround options, and endorses service decisions.
- **DPO/Privacy Officer (DPO):** leads privacy breach assessment and notification guidance when personal data is involved.
- **Legal Counsel (LEGAL):** advises on contractual/legal implications and communications constraints.
- **Procurement (PROC):** manages supplier engagement, contractual levers, and commercial actions.
- **Senior Residual Risk Acceptor (SRRA):** approves material residual risk decisions per governance.
- **Operations / Service Management (OPS):** supports service continuity, monitoring, and operational communications.

5. Incident classification and severity

5.1 Incident types (supplier context)

- Data breach / unauthorised access

- Credential/secret compromise
- Integrity compromise (tampering, malicious updates, supply chain)
- Availability incident (ransomware, outage, denial of service)
- Privacy incident (personal data exposure or misuse)
- Control failure (loss of logging, MFA disablement, assurance lapse)

5.2 Severity levels

Severity 1 (Major):

- confirmed/highly likely impact to in-scope data or critical services, or
- compromise of privileged access paths/tokens, or
- extended outage affecting critical business services.

Severity 2 (Significant):

- potential impact with incomplete facts; limited or contained effect.

Severity 3 (Advisory):

- no evidence of impact to our scope, but relevant due to shared components or exposure.

6. Response timelines (minimum)

- Severity 1: initiate within 2 business hours (or as soon as detected).
- Severity 2: initiate within 1 business day.
- Severity 3: initiate within 5 business days (or sooner if risk context demands).

7. Playbook phases

Phase A — Detect, intake, and mobilise

Owner: SIL + TPSPO

Steps:

1. Log incident record (supplier, service, tier, time received, source).
2. Confirm supplier contact details and establish a comms channel.
3. Assign incident severity (initial) and assemble stakeholders:
 - SEA, ITPO, BSO, PROC, DPO/LEGAL as needed, OPS as needed.
4. Issue the "First 60-Minute Questions" to supplier (if supplier-reported). Outputs:
 - Incident record opened, severity assigned, stakeholder group convened.

Phase B — Situational awareness (what's impacted)

Owner: SIL + SEA

Minimum questions to answer:

- Are we impacted (tenant/data/integration/availability)?
- What data types are in scope (PII/financial/auth secrets)?
- Are privileged paths/integration secrets potentially compromised?
- Is this an availability event affecting critical services?
- Are sub-processors involved? Outputs:
- Initial impact assessment: confirmed / suspected / no evidence.
- Updated severity and response plan.

Phase C — Containment (reduce exposure)

Owner: ITPO (execution) + SIL (direction)

Containment actions (select as applicable; record timestamps): Identity & access:

- Disable supplier accounts; remove admin roles.
- Enforce/strengthen conditional access; temporarily disable SSO integration if required.
- Disable break-glass accounts used by supplier (where safe).

Secrets and integrations:

- Rotate/revoke API keys, tokens, certificates, signing keys.
- Reduce API scopes; disable write access.

- Pause automations/jobs dependent on supplier tokens.

Connectivity:

- Suspend VPN/private links; restrict firewall rules.
- Block inbound connectivity and remote support tooling access.
- Isolate environments or restrict data flows.

Monitoring:

- Increase logging and alerting for supplier-related activity.
- Preserve logs and evidence relevant to the incident timeframe. Outputs:
- Containment actions log + evidence location.

Phase D — Supplier engagement and evidence gathering

Owner: PROC (coordination) + SEA (technical) + LEGAL (as needed)

Actions:

- Send full "Supplier Incident Information Request (Questionnaire)".
- Request:
 - timeline, affected systems, customer impact determination,
 - IOCs/detection guidance,
 - containment/eradication steps,
 - sub-processor involvement,
 - preliminary RCA and corrective actions.
- Define update cadence and escalation path for non-responsiveness. Outputs:
- Supplier responses captured; missing information tracked with ETAs.

Phase E — Privacy, legal, and contractual actions

Owner: DPO + LEGAL

Actions (as applicable):

- Determine if personal data is involved and assess notification obligations.

- Validate supplier notification meets contractual commitments.
- Preserve evidence required for legal/regulatory actions.
- Identify contractual levers and positions (service credits, audit rights, termination). Outputs:
- Privacy impact summary and required notifications/actions.
- Legal/contractual action plan.

Phase F — Reassessment and decision (continue/restrict/suspend/offboard)

Owner: TPSPO + BSO + SEA (with SRRA if required)

Actions:

- Reassess supplier against minimum requirements and incident findings:
 - IAM, privileged access, logging, vuln mgmt, IR maturity, sub-processors, resilience.
- Update tier if needed.
- Define conditions/remediation and compensating controls.
- Determine decision outcome:
 - Continue
 - Continue with Conditions (remediation required)
 - Restrict scope (remove privileged access, disable write APIs, limit data flows)
 - Suspend service pending remediation
 - Initiate offboarding planning
- Escalate to SRRA for material Critical residual risk decisions per governance. Outputs:
- Decision record + approvals.
- Updated gap log, exception records (if MUST impacted), remediation plan.

Phase G — Remediation tracking and validation

Owner: SEA + TPSPO

Actions:

- Track corrective actions with owners/dates.
- Require evidence of remediation and revalidate key controls.

- Review supplier final RCA and confirm preventive controls.
- Close or renew exceptions with new expiry and checkpoints. Outputs:
- Remediation tracker updates; validation evidence stored.

Phase H — Closure and lessons learned

Owner: SIL + TPSPO

Closure criteria (minimum):

- Impact understood and documented.
- Containment actions complete (or consciously maintained).
- Required privacy/legal actions completed.
- Decisions recorded and approved.
- Remediation actions scheduled with owners and due dates (or completed and validated).

Lessons learned:

- Identify improvements to tiering rules, baselines, integration patterns, monitoring, and contractual positions.
- Update templates/playbooks as required.

Outputs:

- Closed incident-triggered review record.
- Lessons learned summary and change actions.

8. Key artifacts (where to store)

- Incident record (internal ticket/reference)
- Supplier comms (emails, updates, questionnaire responses)
- Containment actions log + screenshots/exports
- IOC/detection guidance and internal hunt notes (if applicable)
- Impact assessment, decisions, approvals

- Gap log and remediation plan
- Exceptions and residual risk acceptance records
- Final RCA and closure evidence

9. Reporting requirements (minimum)

For Severity 1/2 incidents, report:

- severity, supplier, service, tier
- impact summary (data/service)
- containment actions taken
- decision (continue/restrict/suspend/offboard)
- remediation plan and dates
- notification performance (supplier vs commitments)
- follow-up actions and accountability

10. Escalation triggers

Immediate escalation required when:

- confirmed/suspected exposure of personal data or authentication secrets
- compromise of privileged access paths
- outage impacting critical business services
- supplier non-responsiveness or missed notification commitments
- material gaps in logging/auditability preventing impact determination